CHANGE MANAGEMENT POLICY

POL-007 | Issued under the Information Management Framework

Document ID: POL-007
Version: 1.0 — DRAFT
Parent Framework: IMF-001 — Information Management Framework
Classification: Internal Use
Owner: Chief Information Officer
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Change Management Policy
Document ID	POL-007
Version	1.0 — DRAFT
Status	Draft for Review
Parent Framework	IMF-001 — Information Management Framework
Document Owner	Chief Information Officer
Custodian	Information Security / IT / Quality Assurance
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]
Regulatory Alignment	21 CFR Part 11, EU Annex 11, GAMP 5 (2022), GxP, SOX (ITGC), ISO/IEC 27001:2022, ITIL 4

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This Policy establishes mandatory requirements for the planning, assessment, authorisation, testing, implementation, and documentation of all changes to [Company Name]'s information systems, infrastructure, and technology environment.

Change is the most common cause of system outages, data integrity failures, security incidents, and regulatory non-compliance. This Policy manages that risk by requiring that all changes — regardless of their apparent simplicity — are assessed, authorised, and documented before implementation, and that the impact on validated system status is considered for every change to a regulated system.

Critically, the rigour of change controls scales with the criticality and regulatory status of the affected system. A change to an internally developed GxP system that creates electronic records has fundamentally different implications from a content update to an internal wiki. This Policy applies proportionate controls — high rigour where the risk is high, lean controls where the risk is low — using the system classification framework established in POL-005 as the governing input.

> **NOTE:** The change management process does not exist to slow down technology delivery. It exists to prevent uncontrolled change from creating outages, security incidents, and regulatory failures that are significantly more disruptive than the change process itself. For GxP systems, uncontrolled change can render a system unvalidated and halt regulated operations until re-validation is complete.

2. Scope

This Policy applies to all changes to:

- Software and applications — including new deployments, version upgrades, patches, configuration changes, and retirement
- Infrastructure — servers, networks, storage, cloud environments, and security controls
- Validated systems — any change to a GxP-validated system (Track A per POL-006) regardless of the perceived impact of the change
- SOX in-scope systems — any change with a potential effect on ITGC effectiveness
- Data and database changes — schema changes, data migrations, and bulk data modifications in production
- Third-party and SaaS systems — vendor-initiated changes, updates, and configuration changes where [Company Name] has control or must be notified

Routine operational activities that are fully documented in an approved Standard Operating Procedure and carried out in strict accordance with that procedure (e.g., scheduled patching within an approved maintenance window, approved account provisioning per access

management procedures) may be classified as pre-approved Standard Changes (see Section 5) and are exempt from individual change request approval, but must still be logged.

3. Change Types

All changes are classified into one of four types. The type determines the approval process and documentation requirements. The change requester proposes the type; the Change Advisory Board (or delegated approver) confirms it.

Change Type	Definition	Typical Examples	Approval Route
Standard Change	A pre-approved, low-risk, repeatable change that follows a documented procedure. Fully pre-assessed and authorised in advance. Individual change request approval is not required — but execution must be logged.	Scheduled OS patching per approved window, approved user account provisioning, standard certificate renewal, approved firewall rule additions within defined policy.	Pre-approved by Change Advisory Board (CAB). Individual executions logged, not approved individually. Periodic review of Standard Change catalogue.
Normal Change	A planned change with sufficient lead time for assessment, testing, approval, and scheduling. The standard path for all non-emergency, non-pre-approved changes.	New software deployment, system upgrade, configuration change, network design change, new integration, database schema change, GxP system update.	Full change request with risk and impact assessment. Approval per Section 6 based on system classification tier and regulatory flags. Implementation only after approval.
Emergency Change	A change that must be implemented with urgency to resolve a critical system failure, address an active security vulnerability being exploited, or prevent imminent significant harm. Speed is prioritised but documentation cannot be eliminated.	Emergency security patch for actively exploited vulnerability, critical system recovery action, urgent fix for production-stopping defect in a Tier 1 system.	Verbal or written approval from CISO and CIO (or designated deputies) before implementation. Full retrospective documentation and formal CAB review within 48 hours. For GxP systems: Compliance / QA notified immediately.
Minor Change	A low-risk, low-impact change to a	Content updates to internal wikis, non-	System Owner approval. Logged in change register. No CAB

Change Type	Definition	Typical Examples	Approval Route
	Tier 3 or Tier 4 non-regulated system that does not affect security controls, data flows, integrations, or system functionality materially.	functional UI changes, low-risk SaaS configuration adjustments that do not affect data storage or sharing.	review required.

IMPORTANT: For GxP systems (Track A under POL-006): there is no Minor Change category. Every change — however apparently trivial — must be assessed for impact on validated status and processed as at minimum a Normal Change. A configuration change that 'just enables a new user field' may directly affect audit trail completeness or electronic signature functionality.

4. Change Risk and Impact Assessment

Every Normal and Emergency Change must be accompanied by a risk and impact assessment. The depth of assessment scales with the system's classification tier and regulatory flags.

4.1 Standard Impact Assessment (All Normal Changes)

All Normal Change requests must address:

- Technical impact: what systems, interfaces, data, and users are affected? Are there dependencies on other systems that may be disrupted?
- Service impact: what is the expected downtime or degradation? During what hours will this occur?
- Security impact: does the change affect access controls, encryption, firewall rules, authentication, or logging?
- Data impact: does the change affect data storage, format, volume, backup, or retention?
- Rollback plan: how will the change be reversed if it causes an incident? What is the rollback trigger criteria?
- Test plan: what testing will be performed before and after implementation to confirm the change is successful?

4.2 GxP Validation Impact Assessment (Track A Systems)

For every change to a GxP-validated system, a validation impact assessment must be completed in addition to the standard impact assessment:

Assessment Question	Validation Response Required
Does the change affect any functionality tested in the current OQ or PQ?	Yes → re-testing of affected test cases required. Identify test cases from current validation protocols.
Does the change affect audit trail configuration, fields captured, or audit trail accessibility?	Yes → immediate escalation to Compliance / QA. Audit trail changes carry the highest regulatory risk. Re-validation of affected audit trail functionality required before implementation.
Does the change affect electronic signature functionality or the link between signature and record?	Yes → Compliance / QA approval required before implementation. Re-testing of electronic signature functionality required.
Does the change affect user access controls, authentication methods, or session management?	Yes → assess impact on Part 11 / Annex 11 compliance. Re-testing of access control functionality required.
Does the change affect data storage, format, encryption, or	Yes → assess impact on ALCOA+ (particularly Enduring and Available). Backup validation may be required.

Assessment Question	Validation Response Required
backup?	
Is the change vendor-initiated (e.g., a SaaS platform update)?	Yes → vendor must provide advance notice, release notes, and evidence that their testing covers validated functionality. [Company Name] Compliance / QA reviews vendor evidence and determines whether additional site-specific testing is required.

IMPORTANT: The validation impact assessment determines whether the change can proceed as a Normal Change with post-implementation verification, or whether the system must be taken out of GxP use while re-validation activities are completed. A system cannot be used for GxP activities after an un-assessed change.

4.3 SOX ITGC Impact Assessment (Track B Systems)

For changes to SOX-scoped systems, the impact on ITGC effectiveness must be assessed:

- Does the change affect any controls included in the current SOX ITGC testing scope?
- Does the change affect financial data flows, interfaces, or reporting outputs?
- Will the change require the ITGC control documentation to be updated?

Compliance / QA must be notified of changes to SOX-scoped systems that affect ITGC effectiveness. The external auditor may need to be informed of significant changes to in-scope systems.

5. Standard Change Catalogue

Standard Changes are pre-approved changes that may be executed without individual change request approval. To qualify as a Standard Change, a change type must meet all of the following criteria:

- It is a well-defined, documented procedure with clear steps and known outcomes
- It has been assessed as low risk to service availability, security, data integrity, and regulatory compliance
- It has been successfully executed multiple times without incident
- It is performed within a defined scope (e.g., approved systems, approved time windows, approved parameters only)
- No GxP-validated functionality or SOX ITGC controls are affected

The Standard Change catalogue is maintained by Information Security / IT and reviewed by the CAB at least quarterly. New Standard Change types may only be added following a formal CAB approval. Standard Changes must be logged at execution — the pre-approval does not eliminate the need for a record.

6. Change Approval Authority Matrix

The approval authority for Normal Changes is determined by the criticality tier and regulatory flags of the primary system affected. Where a change affects multiple systems at different tiers, the highest tier governs.

System Type	Standard Impact	Validation Impact	Approval Authority	CAB Review
Track A — GxP (any criticality tier)	Information Security + System Owner	Compliance / QA must approve all changes with any validation impact. For Major Impact changes: Compliance / QA issues new release decision post-implementation.	Compliance / QA (for validation impact) + System Owner + Information Security	Mandatory for all Normal Changes
Track B — SOX (non-GxP)	System Owner + Information Security	N/A — standard ITGC impact assessment	System Owner + Information Security. Compliance / QA notified if ITGC-affecting.	Mandatory for changes affecting ITGC controls
Track C — Tier 1 (no regulatory flag)	System Owner + Information Security	N/A	System Owner + Information Security +	Mandatory

System Type	Standard Impact	Validation Impact	Approval Authority	CAB Review
			CIO for Tier 1	
Track C — Tier 2 (no regulatory flag)	System Owner + Information Security	N/A	System Owner + Information Security	Mandatory
Track D — Tier 3 (no regulatory flag)	System Owner	N/A	System Owner	Not required
Track D — Tier 4 (no regulatory flag)	System Owner	N/A	System Owner	Not required
Emergency Change (any system)	CISO + CIO (verbal/written before implementation)	Compliance / QA notified immediately for GxP systems	CISO + CIO (pre-implementation) + CAB retrospective review within 48 hours	Retrospective — mandatory within 48 hours

7. Change Advisory Board (CAB)

The Change Advisory Board is the governance body responsible for reviewing, approving, and overseeing Normal Changes in scope for CAB review (per Section 6). The CAB meets on a regular cadence and provides a forward-look change schedule to minimise conflicts and co-ordinate implementation windows.

7.1 CAB Composition

Member	Role in CAB
Chair: Information Security or IT Service Manager	Facilitates meetings. Maintains change register. Manages Standard Change catalogue. Reports CAB metrics to ISSG.
System Owners (affected systems)	Provides system context and approves changes to their systems.
Compliance / QA (for Track A/B changes)	Reviews validation and ITGC impact assessments. Issues release decisions. Attends all meetings where GxP or SOX systems are on the agenda.
Information Security	Reviews security impact of all changes. Approves changes affecting security controls.
Data Custodian (IT)	Provides technical implementation input. Confirms rollback feasibility.
Business stakeholders (as needed)	Attends for changes with significant business impact in their domain.

7.2 CAB Meeting Cadence

The CAB meets weekly under normal operations. The weekly CAB reviews all Normal Changes submitted since the previous meeting, approves or defers them, and maintains the forward change schedule.

An Emergency CAB (ECAB) consisting of the CAB Chair, CISO, and CIO (or designated deputies) is convened on demand for Emergency Changes that cannot wait for the weekly meeting. Emergency CAB decisions are documented within 4 hours of the decision and presented at the next weekly CAB.

8. Change Process — Normal Change

Step 01	**Raise Change Request** The requester submits a Change Request (CR) via the ITSM system. Mandatory fields: • System(s) affected with their POL-005 classification tier and regulatory flags • Description of the change and reason for it • Proposed implementation date and time window • Standard impact assessment (Section 4.1) • For Track A: validation impact assessment (Section 4.2) • For Track B: ITGC impact assessment (Section 4.3) • Test plan • Rollback plan	Responsible **Change Requester**
Step 02	**Technical Review** Information Security and the relevant Data Custodian (IT) review the change request for technical completeness and feasibility: • Is the impact assessment complete and accurate? • Is the rollback plan feasible? • Are there scheduling conflicts with other approved changes? • Are there infrastructure or capacity implications? • For GxP systems: is the validation impact assessment complete?	Responsible **Information Security / Data Custodian (IT)**
Step 03	**Testing in Non-Production Environment** Before CAB approval, all Normal Changes to Track A, B, and C systems must be tested in a non-production environment that accurately reflects the production configuration: • The test environment must be representative of production — a materially different test environment invalidates the testing • For Track A: testing must follow the validation impact assessment conclusions — critical requirements must be retested if the change affects them • Test outcomes must be documented: pass/fail for each test, any anomalies, and confirmation that the rollback procedure has been tested • For Track D: testing may be conducted in the production environment for changes with no data loss risk, with the System Owner's explicit approval	Responsible **Data Custodian (IT) / System Owner / Compliance / QA (Track A)**

Step 04	**CAB Review and Approval** The CAB reviews the change request, test evidence, and all impact assessments: • For Track A: Compliance / QA confirms the validation impact assessment is complete and approves the change to proceed (and issues the release decision approach if Major Impact) • The CAB approves, defers (pending additional information or testing), or rejects the change • If approved: a formal implementation window is scheduled • If deferred: the requester addresses the CAB's questions and resubmits • Changes approved by CAB are logged in the change register with approval date and approvers	Responsible **CAB / Compliance / QA**
Step 05	**Implementation** The change is implemented in the approved implementation window: • Implementation must follow the documented implementation procedure — no in-flight improvisation • A peer reviewer must be available during implementation of changes to Tier 1 systems and all Track A systems — two-person confirmation for critical steps • Progress is logged in the ITSM system in real time • If unexpected issues arise during implementation: the pre-defined rollback criteria must be assessed immediately. If rollback criteria are met, implement rollback and raise a new CR to address the root cause before reattempting • Implementation completion is confirmed in the ITSM system	Responsible **Data Custodian (IT) / System Owner**
Step 06	**Post-Implementation Verification (PIV)** After implementation, the System Owner and Data Custodian (IT) execute the post-implementation verification: • Confirm the system is functioning as expected post-change • Confirm no unintended side effects on adjacent systems or integrations • For Track A: Compliance / QA confirms the post-implementation state meets the validated specification. For Minor Impact changes: PIV confirmation closes the CR. For Major Impact changes: this feeds into the new release decision • PIV results are documented in the ITSM system and the CR is closed	Responsible **System Owner / Data Custodian (IT) / Compliance / QA (Track A)**
Step 07	**Release Decision Update (Track A, Major Impact only)** Where the validation impact assessment classified the change as Major Impact: • Compliance / QA reviews all re-testing evidence and confirms the system remains in a validated state • A new or updated release decision is issued and added to the Validation Master File • The VMF, URS, and qualification protocols are updated to reflect the change • Until the release decision is issued, the system must not be used for GxP activities affected by the change	Responsible **Compliance / QA**

9. Emergency Change Process

Emergency Changes are implemented under time pressure, but must still be managed in a controlled manner. The following is mandatory regardless of urgency.

Step	Action	Timing	Responsible
1	Obtain verbal or written approval from CISO and CIO (or designated deputies) before implementation commences. Document the approval (date, time, method, names).	Before implementation	Change Requester
2	For Track A systems: notify Compliance / QA immediately. QA determines whether the system must be taken out of GxP use during and after the change, pending assessment.	Immediately upon identification	Change Requester / System Owner
3	Implement the change. Document each step in the ITSM system in real time. Log any deviations from the intended implementation.	During implementation	Data Custodian (IT)
4	Post-implementation verification: confirm the emergency is resolved and the system is functioning. Document outcomes.	Within 2 hours	System Owner
5	Raise a formal Change Request in the ITSM system retrospectively. Include full impact assessment, implementation record, and PIV results.	Within 4 hours	Change Requester
6	Emergency CAB (ECAB) retrospective review: CAB Chair, CISO, and CIO review the emergency change, confirm controls were adequate, and add the change to the change register.	Within 48 hours	CAB Chair / CISO / CIO
7	For Track A systems: Compliance / QA completes the validation impact assessment retrospectively and determines whether re-validation is required. Until this is complete, the GxP use status of the system remains under review.	Within 5 business days	Compliance / QA

IMPORTANT: Emergency Changes are the highest-risk change type. Regulators and auditors scrutinise them closely — particularly emergency changes to GxP and SOX systems. The retrospective documentation must be as rigorous as the prospective documentation would have been for a Normal Change. 'We fixed it quickly' is not a substitute for controlled process.

10. Change Freeze Periods

Change freeze periods are designated windows during which Normal Changes are suspended. Emergency Changes may still be implemented during a freeze period, with escalated approval. Freeze periods are published in advance via the IT change calendar.

Freeze Period Type	Trigger	Duration	What Is Frozen
Financial close freeze	SOX-relevant: end of each financial quarter	Typically 2 weeks surrounding the quarter-end close	All changes to SOX in-scope systems. Emergency changes: CISO + CFO approval.
Regulatory inspection freeze	Announced GxP, SOX, or privacy regulatory inspection	From 2 weeks before inspection until inspection close	All changes to systems in inspection scope. Emergency changes: CISO + Compliance / QA approval.
High-risk deployment freeze	CIO or CAB discretion for major infrastructure changes or migrations	As defined for the specific deployment	Changes that could interfere with the major deployment. CAB manages exceptions.
Holiday freeze	Major public holiday periods	As defined in IT change calendar	Non-critical Normal Changes. Emergency changes proceed per standard emergency process.

11. Roles and Responsibilities

Role	Responsibility
CIO	Policy owner. Approves Standard Change catalogue changes. Participates in ECAB. Accountable for overall change management programme effectiveness.
CISO	Approves Emergency Changes. Reviews security impact of all changes. Participates in ECAB. Escalates changes with major security impact to CIO.
CAB Chair	Typically Information Security or IT Service Manager. Facilitates weekly CAB. Maintains change register. Reports CAB metrics. Manages Standard Change catalogue.
System Owner	Approves changes to their system. Provides business context for impact assessment. Confirms post-implementation verification. Ensures Track assignment is current.
Compliance / QA	Reviews and approves validation impact assessments for Track A systems.

Role	Responsibility
	Issues release decisions. Participates in CAB for all Track A and B agenda items. Manages GxP use status of systems under change.
Data Custodian (IT)	Executes changes. Documents implementation steps. Executes rollback where triggered. Provides test environment management.
Information Security	Reviews security impact of all changes. Approves changes affecting security controls. Maintains Standard Change catalogue security assessment.
Change Requester	Any employee may raise a change request. Responsible for completing the CR accurately, obtaining necessary technical input, and following up on CAB outcomes.

12. Related Documents

Document ID	Title	Relationship
IMF-001	Information Management Framework	Parent framework
POL-003	Data Integrity Policy	Uncontrolled change to GxP systems is the leading cause of data integrity failures — this Policy prevents it
POL-005	System Classification Policy	System classification tier and regulatory flags determine change type eligibility and approval authority
POL-006	Computer System Validation and Qualification Policy	Track assignment per POL-006 determines validation impact assessment requirements; change impact on validation status assessed per Section 4.3 of POL-006
POL-008	Access Control Policy	Changes to access controls and user permissions governed by POL-008 access review requirements
POL-009	Privileged Access Management Policy	Changes to privileged access configurations require PAM oversight
POL-010	Information Security Risk Policy	Technical risk mitigations are implemented via POL-007 change management; risk treatment plan reference numbers are recorded in change requests to create a traceable link between identified risks and their remediation
POL-011	Business Continuity Policy	Change freeze periods and rollback planning coordinate with BC/DR plan requirements
POL-012	Incident Response Policy	Failed changes that cause service disruption or

Document ID	Title	Relationship
		data integrity issues may trigger incident response
POL-015	IT Service Management and Operational Incident Policy	All emergency fixes applied during operational incidents are POL-007 emergency changes; Incident ID and Problem Record ID are referenced in the change record; GxP system fixes require validation impact assessment
SOP-003	Data Integrity Process	Data integrity incidents may be caused by uncontrolled change — DIRA updated to reflect new controls post-incident
EXC-001	Exception Management Policy and Register	Change management exceptions have a 3-month maximum duration under EXC-001; exceptions enabling uncontrolled changes to GxP systems are non-approvable per EXC-001 Section 5; all change management exceptions require CISO approval
RACI-001	Roles, Responsibilities and Authorities	CAB membership and change approval accountability

13. Definitions

Term	Definition
Change Advisory Board (CAB)	The governance body that reviews, approves, and schedules Normal Changes. Includes technical, quality, security, and business stakeholders.
Change Freeze Period	A designated period during which Normal Changes are suspended to protect system stability during critical business or regulatory events.
Emergency Change	A change that must be implemented urgently to resolve a critical failure or active security threat, with retrospective documentation and CAB review.
Minor Change	A low-risk change to a non-regulated Tier 3/4 system that requires System Owner approval only. Not applicable to Track A (GxP) systems.
Normal Change	A planned change following the full change request, assessment, approval, testing, and implementation process.
Post-Implementation Verification (PIV)	Documented confirmation that a change has been implemented successfully and that the system is operating as expected post-change.
Release Decision	The formal written approval from Compliance / QA confirming that a GxP system (or functionality affected by a change) is in a validated state and approved for GxP use.
Rollback Plan	The documented procedure for reversing a change if it causes adverse effects, including the criteria that trigger rollback.

Term	Definition
Standard Change	A pre-approved, repeatable, low-risk change type authorised in advance by the CAB. Individual instances are logged but do not require separate CAB approval.
Validation Impact Assessment	The evaluation — required for all changes to Track A GxP systems — of whether and how the change affects the system's validated status.

— End of Document —

POL-007 v1.0 DRAFT | [Company Name] | CONFIDENTIAL